

AP15 - SUDO, UFW

Contraintes :

- Créez le GANTT pour cette nouvelle AP

<https://docs.google.com/spreadsheets/d/1w7c7pt27qDMkHVyMaxx1tlUD4BK058pw9lxdegg86PQ/edit?usp=sharing>

- Complétez votre schéma réseau et votre document de synthèse sur les VLANs et VMs créés dans votre environnement.

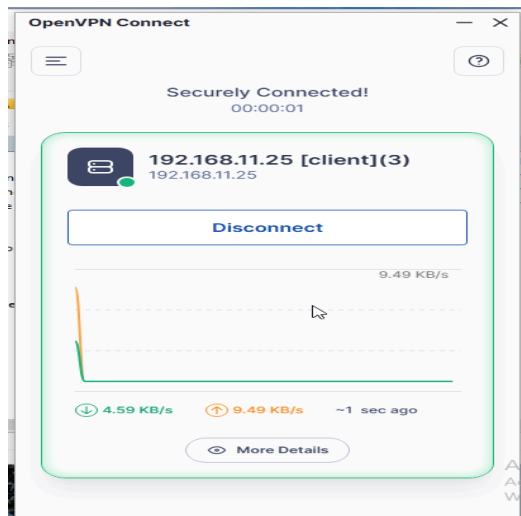
<https://drive.google.com/file/d/1li0QvnRg0LMKsr8WWs5MP0A9ub8fYe2r/view?usp=sharing>

Prérequis :

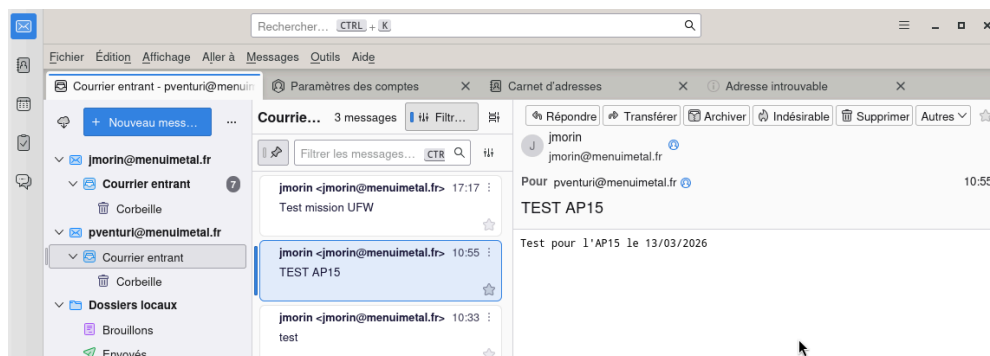
Avant de réaliser cette activité, plusieurs éléments de l'infrastructure doivent être déjà opérationnels.

Les prérequis sont les suivants :

- Serveur OpenVPN et client VPN fonctionnels.



- Serveur de mail et client de messagerie fonctionnels.



- Serveur central de log fonctionnel

```

root@SrvRsyslog:~# tail -f /var/log/remote/*/auth.log
==> /var/log/remote/mariadb/auth.log <==
2026-03-13T14:35:16+01:00 mariadb systemd[1]: Finished apt-daily.service - Daily apt download activities.
2026-03-13T15:17:01+01:00 mariadb CRON[1230]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-03-13T15:17:01+01:00 mariadb CRON[1232]: (root) CMD (cd / && run-parts --report /etc/cron.hourly)
2026-03-13T15:17:01+01:00 mariadb CRON[1230]: pam_unix(cron:session): session closed for user root
2026-03-13T16:17:01+01:00 mariadb CRON[1280]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-03-13T16:17:01+01:00 mariadb CRON[1282]: (root) CMD (cd / && run-parts --report /etc/cron.hourly)
2026-03-13T16:17:01+01:00 mariadb CRON[1280]: pam_unix(cron:session): session closed for user root
2026-03-13T17:17:01+01:00 mariadb CRON[1328]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-03-13T17:17:01+01:00 mariadb CRON[1330]: (root) CMD (cd / && run-parts --report /etc/cron.hourly)
2026-03-13T17:17:01+01:00 mariadb CRON[1328]: pam_unix(cron:session): session closed for user root
==> /var/log/remote/vpn/auth.log <==
2026-03-13T17:08:57+01:00 vpn sshd-session[17928]: Disconnected from user sio 192.168.11.250 port 52846
2026-03-13T17:08:57+01:00 vpn sshd-session[17920]: pam_unix(sshd:session): session closed for user sio
2026-03-13T17:08:57+01:00 vpn sshd-session[17920]: syslogin_perform_logout: logout() returned an error
2026-03-13T17:08:57+01:00 vpn systemd-logind[612]: Session 83 logged out. Waiting for processes to exit.
2026-03-13T17:08:57+01:00 vpn su[19654]: pam_unix(su-l:session): session closed for user root
2026-03-13T17:08:57+01:00 vpn su[19037]: pam_unix(su-l:session): session closed for user adminvpn
2026-03-13T17:08:57+01:00 vpn su[17950]: pam_unix(su-l:session): session closed for user root
2026-03-13T17:08:57+01:00 vpn systemd-logind[612]: Removed session 83.
2026-03-13T17:17:01+01:00 vpn CRON[24603]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-03-13T17:17:01+01:00 vpn CRON[24603]: pam_unix(cron:session): session closed for user root

```

2] Sudo ou « l'affinage » des privilèges

Réponses aux questions

- **Concept de moindre privilège** : Donner à chaque utilisateur ou processus **uniquement** les droits strictement nécessaires.
- **Groupe par défaut sous Debian** : sudo
- **Vérifier appartenance à un groupe** : groups utilisateur ou id utilisateur ou cat /etc/group
- **Fichier sudoers** : /etc/sudoers → définit qui peut faire quoi avec sudo
- **Commande visudo** : Édite le fichier sudoers en vérifiant la syntaxe et en évitant les conflits. Avantage : empêche de casser sudo.

• **Un administrateur dédié (adminvpn) doit être le seul à pouvoir administrer le service openvpn par l'utilisation du script easysrsa, sans avoir à saisir son mot de passe.**

- Création de l'utilisateur adminvpn.

```

root@vpn:~# adduser adminvpn
Nouveau mot de passe :
Retapez le nouveau mot de passe :

```

L'utilisateur **adminvpn** est créé afin de disposer d'un compte dédié à l'administration du service **OpenVPN**. Cette séparation des comptes permet d'appliquer le **principe du moindre privilège**, en limitant les actions de chaque administrateur à son domaine de responsabilité.

- Modification sudoers avec visudo.

```
root@vpn:~# sudo visudo
```

*Le fichier `/etc/sudoers` est modifié à l'aide de la commande **visudo**.*

- Ajouter la directive `adminvpn ALL=(root) NOPASSWD:`
/etc/openvpn/easy-rsa/easyrsadans le fichier.

```
# Allow members of group sudo to execute any command
%sudo    ALL=(ALL:ALL) ALL
adminvpn ALL=(root) NOPASSWD: /etc/openvpn/easy-rsa/easyrsa
```

Afin d'autoriser l'utilisateur **adminvpn** à exécuter le script **easyrsa** avec les privilèges root sans avoir à saisir de mot de passe, la règle ajoutée à l'utilisateur adminvpn permet donc :

- d'exécuter les commandes nécessaires à la gestion des certificats VPN
- sans donner un accès administrateur complet au système.

*Cette configuration améliore la **sécurité** et la **gestion des privilèges**.*

- Test script easyrsa.

[illegible]

Un test est réalisé afin de vérifier que l'utilisateur **adminvpn** peut exécuter les commandes **easysrsa** sans avoir à saisir de mot de passe.

*La création d'un certificat client permet de confirmer que la configuration du fichier **sudoers** fonctionne correctement.*

• **Un administrateur dédié (adminutil) doit être le seul à pouvoir administrer les utilisateurs systèmes créés sur le serveur Linux utilisé pour Openvpn.**

- Création de l'utilisateur adminutil.

```
root@vpn:~# adduser adminutil
Nouveau mot de passe : _
```

Un second compte administrateur nommé adminutil est créé afin de gérer les utilisateurs du système Linux.

- Ajout règles d'administration des utilisateurs du serveur vpn dans fichier sudoers.

```
# Allow members of group sudo to execute any command
%sudo    ALL=(ALL:ALL) ALL
adminvpn ALL=(root) NOPASSWD: /etc/openvpn/easy-rsa/easyrsa
adminutil ALL=(root) /usr/sbin/useradd /usr/sbin/userdel /usr/sbin/usermod
```

Ce compte aura uniquement les permissions nécessaires pour créer ou supprimer des utilisateurs.

- Gestion des utilisateurs : création utilisateur user1.

```
adminutil@vpn:~$ sudo useradd user1
[sudo] Mot de passe de adminutil :
```

Un utilisateur nommé **user1** est créé afin de tester les permissions attribuées à l'administrateur **adminutil**.

- Vérification création user1.

```
adminutil@vpn:~$ groups user1
user1 : user1
adminutil@vpn:~$ groups user1
```

La commande `groups` permettant d'afficher les utilisateurs du système et leur groupes affiliés est utilisée afin de vérifier que l'utilisateur **user1** a bien été créé.

- Suppression user1.

```
adminutil@vpn:~$ sudo userdel user1
[sudo] Mot de passe de adminutil :
```

L'utilisateur **user1** est ensuite supprimé afin de vérifier que l'administrateur **adminutil** possède également les droits nécessaires pour supprimer un compte utilisateur. Cette manipulation permet de valider la configuration des privilèges.

- Vérification suppression user1.

```
adminutil@vpn:~$ groups user1
groups: 'user1' : utilisateur inexistant
```

La commande `groups` confirme la suppression de l'utilisateur user1.

• **Les logs générés par sudo (fichier `/var/log/auth.log` à condition d'avoir installé `rsyslog`) devront être redirigés vers votre serveur central `rsyslog`. Vous pouvez également consulter en local les logs avec la commande `journalctl _COMM=sudo`).**

- Installation de `rsyslog` sur `openvpn`.

```
root@vpn:~# apt install rsyslog
```

Le service **`rsyslog`** est installé afin de gérer la collecte et la centralisation des journaux système.

- Création du fichier de configuration des logs.

```
root@vpn:~# vim /etc/rsyslog.d/50-central-logs.conf
```

La configuration de **`rsyslog`** est modifiée afin de rediriger les journaux d'authentification vers le serveur central de logs dont l'adresse IP est : **192.168.13.8**

```
auth,authpriv.* @@192.168.13.8:514
```

Cette centralisation permet de **faciliter la surveillance et l'analyse des événements de sécurité**.

- Redémarrage du service `rsyslog`.

```
root@vpn:~# systemctl restart rsyslog
```

Redémarrage du service `rsyslog` pour que les changements soient pris en compte.

- Création du fichier de récupération de log sur le serveur Rsyslog

```
root@SrvRsyslog:~# vim /etc/rsyslog.d/20-vpn-auth.conf
```

- Configuration du fichier

```
$template RemoteLogs, "/var/log/remote/%HOSTNAME%/auth.log"

if $programname == 'sshd' then ?RemoteLogs
& stop
```

Indication du chemin souhaité pour la redirection des logs.

- Création du dossier qui accueillera le fichier rsyslog pour openvpn

```
root@SrvRsyslog:~# mkdir -p /var/log/remote
```

- Modification des permissions et droits.

```
root@SrvRsyslog:~# chown root:root /var/log/remote
```

```
root@SrvRsyslog:~# chmod 755 /var/log/remote
```

Redémarrage du service rsyslog.

```
root@SrvRsyslog:~# systemctl restart rsyslog
```

Redémarrage du service rsyslog pour que les changements soient pris en compte.

- Test des logs.

```
root@SrvRsyslog:~# tail -f /var/log/remote/*/auth.log
2026-03-13T14:13:46+01:00 vpn groupadd[19864]: group added to /etc/group: name=sala, GID=1004
2026-03-13T14:13:46+01:00 vpn groupadd[19864]: group added to /etc/gshadow: name=sala
2026-03-13T14:13:46+01:00 vpn groupadd[19864]: new group: name=sala, GID=1004
2026-03-13T14:13:46+01:00 vpn useradd[19869]: new user: name=sala, UID=1004, GID=1004, home=/home/sala, shell=/bin/bash, fr
om=/dev/pts/0
2026-03-13T14:14:11+01:00 vpn passwd[19878]: pam_unix(passwd:chauthtok): password changed for sala
2026-03-13T14:14:14+01:00 vpn chfn[19882]: changed user 'sala' information
2026-03-13T14:14:14+01:00 vpn gpasswd[19889]: members of group users set by root to sio,adminvpn,adminutil,sala
```

Après redémarrage du service rsyslog, les logs générés par sudo sont bien envoyés vers le serveur de logs.

Cela permet aux administrateurs de surveiller les actions réalisées avec des privilèges élevés.

5] UFW ou le pare-feu « facile » (sur serveur de mail postfix)

Le pare-feu **UFW (Uncomplicated Firewall)** est utilisé afin de simplifier la configuration des règles de filtrage réseau sous Linux.

UFW repose sur **iptables** mais propose une interface plus simple pour l'administration.

- Installation UFW.

```
root@postfix:~# apt install ufw -y
```

*Le paquet **ufw** est installé sur le serveur afin de mettre en place un pare-feu local permettant de contrôler les connexions réseau entrantes et sortantes.*

- UFW status.

```
root@postfix:~# ufw status
Status: inactive
root@postfix:~#
```

*Après installation, le pare-feu est présent sur le système mais **désactivé par défaut**.*

- Activer UFW

```
root@postfix:~# ufw enable
Firewall is active and enabled on system startup
root@postfix:~#
```

Commande permettant d'activer UFW.

```
root@postfix:~# ufw status
Status: active
```

En refaisant un `ufw status`, le statut est bien affiché comme actif.

- Installation du paquet rsyslog sur le serveur de mail.

```
root@postfix:~# apt install rsyslog_
```

L'installation du paquet rsyslog est indispensable à la génération de log.

- Logs UFW.

```
root@postfix:~# tail -f /var/log/ufw.log
2026-03-13T16:31:43.818815+01:00 postfix kernel: [UFW BLOCK] IN=ens18 OUT= MAC=bc:24:11:11:9f:65:bc:24:11:28:69:35:08:00 SRC=192.168.12.4 DST=192.168.12.7 L
2 TOS=0x00 PREC=0x00 TTL=64 ID=27542 DF PROTO=TCP SPT=52506 DPT=143 WINDOW=488 RES=0x00 ACK URG=0
2026-03-13T16:31:43.818816+01:00 postfix kernel: [UFW BLOCK] IN=ens18 OUT= MAC=bc:24:11:11:9f:65:bc:24:11:28:69:35:08:00 SRC=192.168.12.4 DST=192.168.12.7 L
2 TOS=0x00 PREC=0x00 TTL=64 ID=27543 DF PROTO=TCP SPT=52506 DPT=143 WINDOW=488 RES=0x00 ACK URG=0
2026-03-13T16:31:43.818817+01:00 postfix kernel: [UFW BLOCK] IN=ens18 OUT= MAC=bc:24:11:11:9f:65:bc:24:11:28:69:35:08:00 SRC=192.168.12.4 DST=192.168.12.7 L
2 TOS=0x00 PREC=0x00 TTL=64 ID=27544 DF PROTO=TCP SPT=52506 DPT=143 WINDOW=488 RES=0x00 ACK URG=0
2026-03-13T16:31:43.818817+01:00 postfix kernel: [UFW BLOCK] IN=ens18 OUT= MAC=bc:24:11:11:9f:65:bc:24:11:28:69:35:08:00 SRC=192.168.12.4 DST=192.168.12.7 L
2 TOS=0x00 PREC=0x00 TTL=64 ID=27545 DF PROTO=TCP SPT=52506 DPT=143 WINDOW=488 RES=0x00 ACK URG=0
2026-03-13T16:31:43.818818+01:00 postfix kernel: [UFW BLOCK] IN=ens18 OUT= MAC=bc:24:11:11:9f:65:bc:24:11:28:69:35:08:00 SRC=192.168.12.4 DST=192.168.12.7 L
2 TOS=0x00 PREC=0x00 TTL=64 ID=47864 DF PROTO=TCP SPT=52524 DPT=143 WINDOW=486 RES=0x00 ACK URG=0
```

Les logs du pare-feu sont activés afin de pouvoir analyser les connexions autorisées ou bloquées. Ces logs sont consultables dans le fichier : /var/log/ufw.log.

Ils permettent de surveiller les activités réseau suspectes.

- Vérification des règles par défaut (il y en a trois).

```
root@postfix:~# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip
root@postfix:~#
```

*La commande **ufw status verbose** permet de vérifier les règles actuellement actives sur le pare-feu.*

*Les **trois règles par défaut** sont donc :*

- **Incoming** (trafic entrant) → deny (tout est bloqué sauf ce que l'on autorise)
- **Outgoing** (trafic sortant) → allow (tout est autorisé par défaut)
- **Routed** (trafic routé/forward) → disabled
- Désactivation des règles IPv6.

- Modifier la règle par défaut sur le trafic sortant en l'interdisant.

```
new profiles: skip
root@postfix:~# ufw default deny outgoing
Default outgoing policy changed to 'deny'
(be sure to update your rules accordingly)
root@postfix:~# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), deny (outgoing), disabled (routed)
New profiles: skip
```

Cette modification oblige à autoriser explicitement chaque service sortant (SMTP, IMAP, etc.), renforçant ainsi la sécurité du serveur de mail.

- Désactivation des règles IPv6

```
new profiles: skip
root@postfix:~# vim /etc/default/ufw
```

Le fichier de configuration : `/etc/default/ufw` est modifié afin de **désactiver IPv6**.

```
# Set to yes to apply rules to support IPv6 (no means only IPv6 on loopback
# accepted). You will need to 'disable' and then 'enable' the firewall for
# the changes to take affect.
IPV6=no
```

Mettre "no" à la directive 'IPV6' puis enregistrer et quitter le fichier.

Cette modification simplifie la configuration du pare-feu lorsque l'infrastructure utilise uniquement IPv4.

- Test SSH (avant configuration).

```
root@glpi:~# ssh sio@192.168.12.7
ssh: connect to host 192.168.12.7 port 22: Connection timed out
root@glpi:~#
```

UFW bloque SSH car les connexions SSH n'ont pas été permises.

- Permettre l'accès SSH.

```
root@postfix:~# ufw allow ssh
Rule added
Rule added (v6)
root@postfix:~#
```

Une règle est ajoutée afin d'autoriser les connexions **SSH** sur le serveur.

Cette règle est essentielle afin de pouvoir continuer à administrer le serveur à distance après l'activation du pare-feu.

- Vérification des règles.

```
root@postfix:~# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
```

Grâce à la commande **ufw status verbose**, on peut ainsi confirmer que le service ssh est autorisé par le par feu UFW.

- Test SSH (après configuration).

```
root@client-linux:~# ssh sio@192.168.12.7
The authenticity of host '192.168.12.7 (192.168.12.7)' can't be established.
ED25519 key fingerprint is SHA256:PpuM17hi1M6thT218VvcSwRGqf8v3JzL0jcJSEF1+XI.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.12.7' (ED25519) to the list of known hosts.
sio@192.168.12.7's password:
Linux postfix 6.12.48+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.48-1 (2025-09-20) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Nov  7 16:15:15 2025 from 192.168.12.250
sio@postfix:~$
```

L'accès SSH est bien fonctionnel depuis les autres VMs pour le serveur de mail.

- Commandes de gestion du pare-feu.

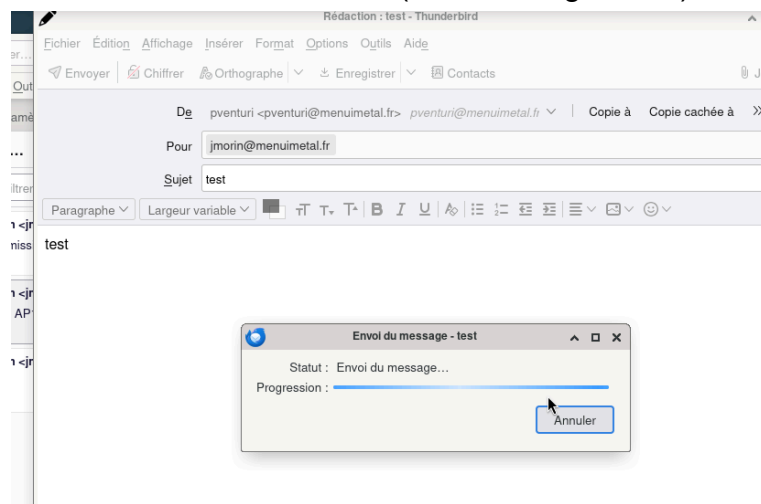
Désactiver le pare-feu : **sudo** **ufw** **disable**.

Réinitialiser la configuration : **sudo** **ufw** **reset**.

Deux commandes importantes permettent de gérer UFW.

Ces commandes permettent de revenir à une configuration initiale en cas d'erreur.

- Test du serveur mail (avant configuration)



Sans la configuration UFW de smtp et imap, le serveur de mail, il est impossible d'envoyer de mails à qui que ce soit, la page reste bloquée à "Envoi du mail".

- Configuration pour le serveur de mail

```
root@postfix:~# ufw allow 25/tcp
Rule added
Rule added (v6)
root@postfix:~# ufw allow 143/tcp
Rule added
Rule added (v6)
```

- `ufw allow 25/tcp` → Autorise le **SMTP** (port 25) pour l'envoi de mails.
- `ufw allow 143/tcp` → Autorise l'**IMAP** (port 143) pour la réception de mails.

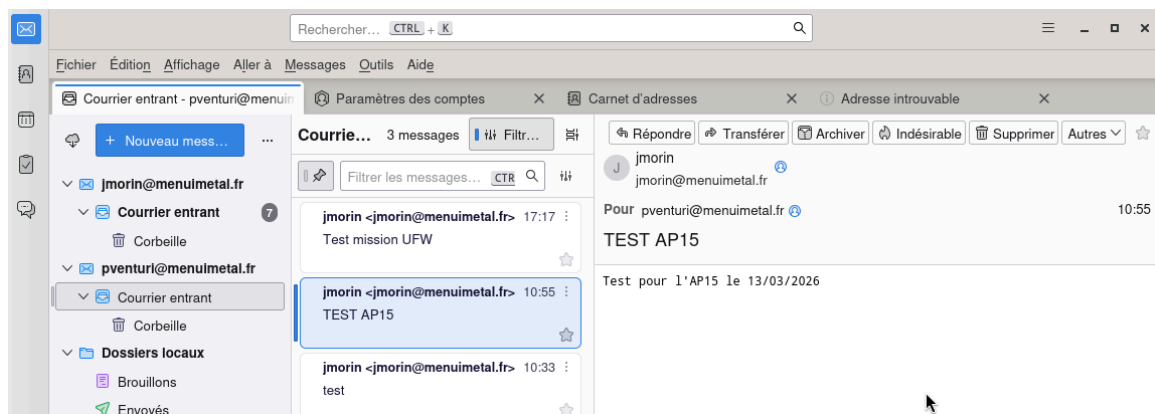
Ces deux règles sont obligatoires car les politiques par défaut sont en deny (entrant + sortant). Sans elles, le serveur de mail ne pourrait ni envoyer ni recevoir de messages.

```
root@postfix:~# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), deny (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
25/tcp ALLOW IN Anywhere
143/tcp ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
25/tcp (v6) ALLOW IN Anywhere (v6)
143/tcp (v6) ALLOW IN Anywhere (v6)
```

Les règles ont bien été ajoutées.

- Test du serveur mail (avant configuration)



Comme visible sur la capture le mail a bien été envoyé et bien reçu après configuration.